令和7年度 秋期
情報処理安全確保支援士試験
午前II 分析

問1〜問25 全問解説 ＋ 情報分野の情勢

試験時間 10:50〜11:30（40分）／全25問必須解答

試験全体の概要

出題構成

全25問 ／ 択一4択 ／ 40分

- セキュリティ系：**16問（64%）**
- 基礎IT系：**9問（36%）**

合格ライン目安：60点（15問）以上

今回の特徴

1. 🔬 AI・量子（PQC）が正面出題
2. ☁️ クラウドセキュリティ2問
3. ⚠️ 攻撃手法4問（多様化）
4. 📋 フレームワーク・組織4問以上
5. 🔧 基礎技術は例年どおり9問

出題カテゴリ分布

カテゴリ	問題番号	問数	比率
暗号技術	問1, 問3, 問9	3	12%
攻撃手法	問2, 問5, 問7, 問8	4	16%
認証・PKI	問4, 問10, 問11	3	12%
Webセキュリティ	問6, 問16	2	8%
セキュリティ管理・組織	問12, 問13, 問14, 問15	4	16%
ネットワーク	問17, 問19, 問20	3	12%
Web技術 / システム・DB / 法律 / 計算 / 監査	問18, 問21〜25	6	24%

セキュリティ関連合計：16問（64%）　基礎IT：9問（36%）

問題難易度の概観

難易度	問題番号	備考
易	問2, 問9, 問12, 問18, 問20	定義・用語の直接問いかけ
標準	問1, 問4, 問6, 問11, 問13, 問14, 問15, 問17, 問19, 問23, 問25	正確な理解が必要
やや難	問3, 問5, 問7, 問8, 問10, 問16, 問21, 問22	紛らわしい選択肢あり
計算	問24	落ち着いて計算すれば正解可能

易問（5問）は確実に取り、標準問題（11問）で合否が決まる。やや難問でも最低4〜5問は正解したい。

暗号技術

問1・問3・問9

CRYPTREC暗号リスト ／ PQC ／ 情報理論的安全性

問1　CRYPTREC暗号リスト

暗号技術　標準

問題文

デジタル庁,総務省及び経済産業省が策定した"電子政府における調達のために参照すべき暗号のリスト（CRYPTREC暗号リスト）"に関する記述のうち、適切なものはどれか。

ア 運用監視暗号リストは,運用監視システムにおける利用実績が十分であると判断され、電子政府において利用を推奨する暗号技術のリストである。

イ 証明書失効リストは,政府共用認証局が公開している,危殆化した暗号技術のリストである。

ウ 推奨候補暗号リストは,安全性及び実装性能が確認され,今後、電子政府推奨暗号リストに掲載される可能性がある暗号技術のリストである。

エ 電子政府推奨暗号リストは,互換性維持目的に限った継続利用を推奨する暗号技術のリストである。

問1　解答・解説

暗号技術　標準

正解：ウ
推奨候補暗号リスト＝安全性・実装性能が確認され、今後推奨リストに掲載される可能性がある暗号技術

CRYPTREC暗号リストの3区分

リスト名	位置付け
電子政府推奨暗号リスト	政府システムで推奨。現役・主力
推奨候補暗号リスト ← ウ	将来の推奨候補。今後昇格予定
運用監視暗号リスト	新規利用不可。互換維持のみ許容

情報分野の情勢
2024年にNISTがPQC標準（ML-KEM/ML-DSA等）を正式公開。CRYPTRECもデジタル庁主導で耐量子暗号への移行計画を策定中。推奨候補リストは量子コンピュータ時代への橋渡しとして重要性が増大。

問3　PQC（Post-Quantum Cryptography）

暗号技術　やや難

問題文

PQC（Post-Quantum Cryptography）はどれか。

ア 量子コンピュータを使うことによって、従来のコンピュータを使うときと比べて暗号化の処理速度を飛躍的に向上させることができる暗号技術

イ 量子コンピュータを使うことによっても従来のコンピュータを使うことによっても,暗号化の処理に掛かる処理時間を一定にできる暗号技術

ウ 量子コンピュータを使った攻撃では、従来のコンピュータを使った攻撃と比べて解読時間が大幅に短くなる可能性のある暗号技術

エ 量子コンピュータを使った攻撃に対しても従来のコンピュータを使って安全性を確保できる暗号技術

問3　解答・解説

暗号技術　やや難

正解：エ
量子コンピュータを使った攻撃に対しても、**従来のコンピュータを使って**安全性を確保できる暗号技術

重要な誤解ポイント

PQCは「量子コンピュータで動作する暗号」ではなく、「量子攻撃に耐える暗号」

- 対象脅威：**Shorのアルゴリズム**（RSA/ECC破壊）、**Groverのアルゴリズム**（対称鍵攻撃）
- 候補技術：格子暗号・符号暗号・多変数多項式暗号

情報分野の情勢
2024年8月、NISTがML-KEM（FIPS 203）・ML-DSA（FIPS 204）・SLH-DSA（FIPS 205）を正式公開。NSA CNSA 2.0は2030〜2033年の移行期限を明示。「Harvest Now, Decrypt Later」攻撃に備え早急な移行が必要。TLS/SSH/VPNへの組み込みが進行中。

問9　情報理論的安全性に基づく暗号技術

暗号技術　易

問題文

情報理論的安全性に基づく暗号技術はどれか。

ア DH 鍵共有　　イ RSA 暗号　　ウ 楕円曲線暗号　　エ ワンタイムパッド

問9　解答・解説

暗号技術　易

正解：エ　ワンタイムパッド（OTP）
鍵長≧平文長 ＋ 真乱数 ＋ 使い捨て の3条件を満たすと、無限の計算能力を持つ攻撃者にも解読不可能

安全性の分類

種別	前提	例
情報理論的安全性	計算能力に依存しない	**ワンタイムパッド**
計算量的安全性	現実的な計算量で解読不可	RSA・DH・楕円曲線暗号

情報分野の情勢
量子鍵配送（QKD）はOTPの原理で完全秘匿通信を実現しようとする技術。東芝・NECが実証実験を推進、政府・金融機関での試験導入が進行中。秘密分散（Secret Sharing）・安全なMPC（マルチパーティ計算）にも応用されている。

攻撃手法

問2・問5・問7・問8

Pass the Hash ／ モデルインバージョン ／ SYN反射型DDoS ／ ドメインフロンティング

問2　Pass the Hash攻撃

攻撃手法　易

問題文

Pass the Hash 攻撃はどれか。
ア パスワードのハッシュ値から導出された平文パスワードを使ってログインする。
イ パスワードのハッシュ値だけでログインできる仕組みを悪用してログインする。
ウ パスワードを固定し、利用者 ID の文字列のハッシュ化を繰り返しながら様々な利用者 ID を試してログインする。
エ ハッシュ化されずに保存されている平文パスワードを使ってログインする。

問2　解答・解説

攻撃手法　易

正解：イ
パスワードのハッシュ値だけでログインできる仕組みを悪用し、ハッシュ値そのものを認証トークンとして使用

攻撃フロー

1. SAMデータベース・LSASSメモリからNTLMハッシュを窃取
2. 平文パスワードを復元**せずに**、そのまま別システムへの認証に使用
3. **ラテラルムーブメント**（横断的侵害）に悪用

誤りの選択肢：ア＝パスワードクラック、ウ＝リバースブルートフォース、エ＝平文漏洩

情報分野の情勢
ランサムウェアグループ・APTによる横断的侵害で依然多用。Microsoft はWindows 11でCredential Guard をデフォルト有効化。CISAのKEVカタログに関連手法が頻繁に登録されており被害増加傾向。

問5　AIに対するモデルインバージョン攻撃

攻撃手法　やや難

問題文

AI に対するモデルインバージョン攻撃に該当するものはどれか。

ア AI モデルに対して入力データを調整しながら出力結果の取得を繰り返し行って解析し,学習に用いた元のデータを推測する。

イ AI モデルに対して複数のデータを入力して得られた出力結果を観察することによって,当該 AI モデルを模倣し,同等の性能をもつ AI モデルを得る。

ウ 学習時のデータセットに悪意あるデータを混入し、誤った学習をさせる。

エ 何らかの方法で AI の実行ファイルを入手し,逆アセンブルや逆コンパイルによって AI のソースコードを得る。

問5　解答・解説

攻撃手法　やや難

正解：ア
AIモデルへの入力を調整しながら出力を繰り返し取得・解析し、**学習に用いた元のデータを推測**する

AIへの主要攻撃手法の整理

攻撃名	概要
モデルインバージョン ← ア	出力から学習データを逆算・復元（プライバシー侵害）
モデル抽出攻撃	入出力観察によりモデルを複製
ポイズニング攻撃	学習データ汚染で意図的誤動作
敵対的サンプル攻撃	微小摂動で誤分類を引き起こす

情報分野の情勢
LLM（ChatGPT/Claude等）の急普及でAIセキュリティへの関心が急騰。EU AI Act（2024年発効）はリスク分類とセキュリティ要件を規定。MITREがATLAS（AI攻撃戦術フレームワーク）を公開。日本でもAIガバナンス議論が加速。

問7　SYN/ACKパケット大量観測時の攻撃推定

攻撃手法　やや難

問題文

送信元 IP アドレスが A,送信元ポート番号が 80/tcp,宛先 IP アドレスがホストに割り振られていない未使用の IP アドレスである SYN/ACK パケットを大量に観測した場合,推定できる攻撃はどれか。

ア IP アドレス A を攻撃先とするサービス妨害攻撃
イ IP アドレス A を攻撃先とするパスワードリスト攻撃
ウ IP アドレス A を攻撃元とするサービス妨害攻撃
エ IP アドレス A を攻撃元とするパスワードリスト攻撃

問7　解答・解説

攻撃手法　やや難

正解：ア
IPアドレスAを**攻撃先（被害者）**とするサービス妨害攻撃

SYN反射型DDoS攻撃のメカニズム

```
攻撃者 ─[送信元IP=A に偽装したSYNパケット]─▶ 多数のホスト
                                              │
多数のホスト ─[SYN/ACK をIPアドレスAに返送]──────▶ A（被害者・大量の不要SYN/ACKで過負荷）
```

- 宛先IPが「未使用」→ そのホストはSYNを送ってないから届いたSYN/ACKは偽物（AがSYNを偽装して見せかけている証拠）
- 送信元ポート80 → 正規Webサーバに見せかける偽装

情報分野の情勢
2023〜2024年に数Tbps超の記録的DDoS攻撃が多発（Cloudflare・Akamai報告）。DNS/NTP/QUICを悪用した反射型増幅攻撃の亜種が登場。ISPでのBCP38（送信元アドレス検証）適用が国際的に求められている。

問8　ドメインフロンティングを悪用した攻撃

攻撃手法　やや難

問題文

ドメインフロンティングを悪用した攻撃の例として、適切なものはどれか。
ア マルウェアが,CDN の機能を悪用し、実際の通信先を隠蔽して攻撃者のサーバに接続する。
イ マルウェアが,DNS キャッシュサーバに偽の DNS 情報を蓄積させる。
ウ マルウェアが,送信元 IP アドレスを攻撃対象に偽装した DNS リクエストを多数の DNS キャッシュサーバに送信し、攻撃対象のサーバをダウンさせる。
エ マルウェアが,ドメイン情報を管理しているサイトに不正にアクセスし,ドメイン情報を書き換える。

問8　解答・解説

攻撃手法　やや難

正解：ア
マルウェアがCDNの機能を悪用し、**実際の通信先を隠蔽**して攻撃者のサーバに接続する

ドメインフロンティングの仕組み

レイヤ	指定するドメイン
TLS SNI（外側・監視に見える）	`cdn.example.com`（正規CDN）
HTTP Host ヘッダ（内側・実際の宛先）	`attacker.evil.com`

- ネットワーク監視はSNIしか見えない → 正規CDNへの通信に偽装成功
- **C2通信の隠蔽**に悪用される

情報分野の情勢
ロシア・北朝鮮·イランの国家支援型APTが多用。AWS CloudFront・Googleは対策を実施済みだが「ドメイン隠蔽」「クラウドトンネリング」など派生手法が続出。TLS Inspection（SSL復号検査）の重要性が増大。Cobalt Strike等への組み込みも確認。

認証・PKI

問4・問10・問11

PKIのRA ／ 認証デバイス ／ NIST SP 800-63-3

問4　PKIのRA（Registration Authority）の役割

認証・PKI　標準

問題文

PKI（公開鍵基盤）を構成する RA（Registration Authority）の役割はどれか。

ア デジタル証明書にデジタル署名を付与する。

イ デジタル証明書に紐付けられた属性証明書を発行する。

ウ デジタル証明書の失効リストを管理し,デジタル証明書の有効性を確認する。

エ 本人確認を行い,デジタル証明書の発行申請の承認又は却下を行う。

問4　解答・解説

認証・PKI　標準

正解：エ
本人確認を行い、デジタル証明書の発行申請の**承認または却下**を行う

PKIの主要コンポーネント

コンポーネント	役割
CA（Certificate Authority）	証明書の発行・署名・失効
RA（Registration Authority）← エ	申請者の本人確認・審査、CAへ通知
VA（Validation Authority）	証明書の有効性確認（OCSP）
AA（Attribute Authority）	属性証明書の発行

情報分野の情勢
IoT・コンテナ普及でマシンアイデンティティの発行件数が急増。Let's Encryptを筆頭にACMEプロトコルが普及し証明書の短命化（47日化を業界が議論）が進行。CAB Forum規則強化でRAの本人確認プロセスにも厳格化の圧力。

問10　認証デバイスに関する記述

認証・PKI　やや難

問題文

認証デバイスに関する記述のうち、適切なものはどれか。
ア USB メモリにデジタル証明書を組み込み、認証デバイスとする場合は、その USB メモリを接続する PC の MAC アドレスをデジタル証明書に組み込む必要がある。
イ 成人の虹彩を用いる虹彩認証では、認証デバイスで用いる虹彩パターンの更新がほとんど不要である。
ウ 静電容量方式の指紋認証デバイスは,LED 照明を設置した室内では正常に認証できない可能性が高い。
エ 認証に利用する接触型 IC カードは、カード内のコイルの誘導起電力を利用している。

問10　解答・解説

認証・PKI　やや難

正解：イ
虹彩認証では、認証デバイスで用いる虹彩パターンの**更新がほとんど不要**である

各選択肢の誤り

選択肢	誤りのポイント
ア	USBトークン証明書に接続先PCのMACアドレスは不要
イ ◯	虹彩は加齢でほぼ変化しない → 更新不要・FAR極めて低い
ウ	LED照明の影響を受けるのは**光学式**（静電容量式は電気的特性を検出）
エ	コイル誘導起電力を使うのは**非接触型**（接触型は物理接点）

情報分野の情勢
パスキー（Passkey）・FIDO2/WebAuthn普及でパスワードレス認証が急拡大。Apple/Google/Microsoftがサポート。マイナンバーカードのスマホ搭載（2023年〜）も進行。ディープフェイクによる顔認証バイパスへの懸念でLiveness Detection技術が重要化。

問11　NIST SP 800-63-3 の Identity Proofing

認証・PKI　標準

問題文

NIST SP 800-63-3 で定義されている Identity Proofing に該当するものはどれか。

ア システムに利用者を登録する際に、利用者本人と写真付き身分証とを照合し,確認する。

イ システムに利用者を登録する際に、利用者本人の希望する利用者 ID が既に別の利用者に利用されていないかどうかを確認する。

ウ 利用者がシステムにログインした際に,システムから利用者に電子メールを送信し,ログインしたことを利用者本人に確認させる。

エ 利用者がシステムにログインする際に、利用者の入力した利用者 ID 及びパスワードとシステムに登録されている情報とを照合し、利用者本人かどうかを確認する。

問11　解答・解説

認証・PKI　標準

正解：ア
システムに利用者を登録する際に、利用者本人と**写真付き身分証とを照合し確認**する

NIST SP 800-63-3 の3要素

要素	内容	正解との関係
Identity Proofing	登録時の本人確認（身分証照合）	**ア** ○
Authentication	ログイン時の本人確認	エが相当
Federation	システム間ID連携	—

IAL（Identity Assurance Level）1〜3で厳格さを段階規定

情報分野の情勢
NISTはSP 800-63-4を策定中（リモートでのオンラインIdentity Proofing強化）。マイナンバーカードを使ったeKYC（JPKI）が金融・行政で急普及。ディープフェイクを使ったKYCバイパス事例も報告され、業界横断的な課題となっている。

Webセキュリティ

問6・問16

XMLデジタル署名 ／ CSRF攻撃対策

問6　XMLデジタル署名の特徴

Webセキュリティ　標準

問題文

XML デジタル署名の特徴はどれか。
ア XML デジタル署名の構文には,CMS（Cryptographic Message Syntax）が用いられる。
イ XML 文書中のエレメントに対するデタッチ署名（Detached Signature）を作成し,同じ XML 文書に含めることができる。
ウ エンベローピング署名（Enveloping Signature）では、一つの署名対象に複数の署名を付与する。
エ 署名対象と署名アルゴリズムは ASN.1 によって記述する。

問6　解答・解説

Webセキュリティ　標準

正解：イ
XML文書中のエレメントに対するデタッチ署名を作成し、**同じXML文書に含める**ことができる

XMLデジタル署名の3形式

形式	説明
エンベロープ署名	署名対象のXML内部に署名を埋め込む
エンベロービング署名	署名要素の内部に署名対象を含める
デタッチ署名 ← イ	署名対象と署名が分離。同一XML文書内に含めることも可能

- CMSはPKCS#7/S/MIMEで使用。ASN.1はCMS側の記述言語。XMLデジタル署名はW3C XMLSig準拠。

情報分野の情勢
電子政府・B2B EDIでXML署名が継続使用。APIエコノミーではJWT/JWSが主流。クラウドサイン等の電子契約急拡大に伴い、eIDAS規則・電子署名法への理解が重要化。

問16　CSRF攻撃の対策として効果がないもの

Webセキュリティ　やや難

問題文

クロスサイトリクエストフォージェリ攻撃の対策として、効果がないものはどれか。
ア Web サイトでの決済などの重要な操作の都度,利用者のパスワードを入力させる。
イ Web サイトへのログイン後,HTTP レスポンスボディに含めた秘密の値と,Web ブラウザから送付される値とを,Web サーバ側で照合する。
ウ Web ブラウザからのリクエスト中の Referer によって正しいリンク元からの遷移であることを確認する。
エ Web ブラウザからのリクエストを Web サーバで受け付けた際に、リクエストに含まれる"<",">"などの特殊文字を,"<",">"などの文字列に置き換える。

問16　解答・解説

Webセキュリティ　やや難

正解：エ（効果なし）
特殊文字（< >等）をHTMLエスケープする → これは**XSS対策**であり、CSRF対策としては無効

有効なCSRF対策

対策	選択肢
CSRFトークン（セッション連動乱数値を検証）	イ ✓
パスワード再入力（重要操作時の追加認証）	ア ✓
Refererチェック（補助的）	ウ ✓
SameSite Cookie属性（Lax/Strict）	—（選択肢なし）

情報分野の情勢
主要ブラウザがSameSite=Laxをデフォルト化し、従来型CSRF攻撃リスクは大幅低減。ただしOWASP Top 10から単独外れただけで脅威は継続。SPA（React/Vue.js）フレームワークでの自動保護への依存度が高まっている。

セキュリティ管理・組織

問12・問13・問14・問15

MITRE ／ PSIRT ／ UEBA ／ CSPM

問12　MITREの役割

セキュリティ管理　易

問題文

MITRE の役割に該当するものはどれか。
ア CVE の事務局であり、サイバー攻撃のプロセスを記述したナレッジベースの公開をする。
イ サイバーセキュリティフレームワーク,コンピュータセキュリティ関連のガイドライン及び技術仕様などを発行する。
ウ 高いレベルのサイバーセキュリティを EU 加盟諸国が達成するための支援をする。
エ 日本国内で発生した情報セキュリティインシデントの受付,対応支援を技術的な立場から行う。

問12　解答・解説

セキュリティ管理　易

正解：ア
CVEの事務局であり、サイバー攻撃のプロセスを記述したナレッジベース（**ATT&CK**）を公開する

主要セキュリティ機関の整理

機関	役割
MITRE ← ア	CVE管理・ATT&CK・CWE（米国非営利）
NIST	サイバーセキュリティFW・ガイドライン発行（米国標準技術研究所）
ENISA	EU加盟国のサイバーセキュリティ支援（欧州）
JPCERT/CC	日本国内インシデント受付・対応支援

情報分野の情勢
MITRE ATT&CK v15（2024年）でGenAIを悪用した攻撃戦術が追加。SIEM/XDR/脅威ハンティングツールへの統合が標準化。CVEの年間発行件数は増加の一途で、JVN・IPAとの連携も強化されている。

問13　自社製品の脆弱性に起因するリスクへの対応

セキュリティ管理　標準

問題文

ある企業で、社内機能として CSIRT, PSIRT, SOC, WHOIS データベースの技術連絡担当組織があるとき、自社製品の脆弱性に起因するリスクに対応するべき社内機能はどれか。

ア CSIRT　イ PSIRT　ウ SOC　エ WHOIS データベースの技術連絡担当組織

問13　解答・解説

セキュリティ管理　標準

正解：イ　PSIRT
Product Security Incident Response Team ＝ 自社製品・サービスの脆弱性に関するリスク対応

セキュリティ組織の役割比較

組織	対象範囲
CSIRT	自組織が**受ける**サイバー攻撃・インシデント
PSIRT ← イ	自社**製品**の脆弱性（収集・分析・修正・公開）
SOC	自組織ネットワークの監視・検知・分析

情報分野の情勢
IoT・コネクテッドカー・ICS/OTへのサイバー攻撃が急増し、製造業でのPSIRT設立が急務。欧州CRA（Cyber Resilience Act）や米国大統領令で製品セキュリティ要件・脆弱性開示が義務化方向。JPCERTがPSIRT支援ガイドライン・トレーニングを提供。

問14　UEBAの機能

セキュリティ管理　標準

問題文

UEBA の機能はどれか。
ア 指紋,静脈などの身体的特徴によって本人確認を行う。
イ 情報への論理的アクセスを制御する。
ウ データを USB メモリに格納する際に暗号化する。
エ 利用者や機器の異常な振る舞いを検知する。

問14　解答・解説

セキュリティ管理　標準

正解：エ
利用者や機器の**異常な振る舞いを検知**する（User and Entity Behavior Analytics）

UEBAの特徴

- ユーザ・エンティティの行動パターンを**機械学習**で分析
- 内部不正・アカウント乗っ取り・ラテラルムーブメントの検知に有効
- UBA（User Behavior Analytics）が進化し、エンティティ（サーバ・デバイス等）分析を追加したもの

他の選択肢との違い：ア＝生体認証、イ＝アクセス制御、ウ＝DLP/暗号化

情報分野の情勢
XDRへの統合でSIEM/EDR/NDRと連携したプラットフォームが主流に。AIによる異常検知精度が向上しSOCアナリストのアラート疲れを軽減。日本の重要インフラ・金融機関で内部不正対策として導入が加速。

問15　CSPMの機能

セキュリティ管理　標準

問題文

CSPM（Cloud Security Posture Management）の機能はどれか。
ア クラウドサービス上に構築したシステムのファイルを継続的に監視し,マルウェア感染を検知する。
イ クラウドサービスの設定を継続的に監視し、不適切な設定を検知する。
ウ クラウドサービスへのアクセスを継続的に監視し,不正アクセスを遮断する。
エ 組織のファイルサーバのデータを継続的に監視し、重要データを暗号化してクラウドサービスのストレージにバックアップを格納する。

問15　解答・解説

セキュリティ管理　標準

正解：イ
クラウドサービスの設定を継続的に監視し、**不適切な設定（misconfiguration）を検知**する

クラウドセキュリティツールの整理

ツール	主な機能
CSPM ← イ	クラウドインフラ設定ミスの検出・修正
CWPP	クラウドワークロード（VM・コンテナ）保護
CASB	クラウドアクセスの可視化・制御
CNAPP	CSPM + CWPP + CIEM の統合プラットフォーム

情報分野の情勢
Gartnerは「クラウドセキュリティ失敗の99%は顧客の設定ミス」と指摘。S3バケット・Blobコンテナの設定ミスによる大規模漏洩が多発。CSPMはCNAPPへ統合進化しており、マルチクラウド・ハイブリッドクラウドの一元管理が重要課題に。

ネットワーク・Web技術

問17・問18・問19・問20

IEEE 802.1X ／ Ajax ／ OSPF ／ HTTPステータスコード

問17　IEEE 802.1Xが規定するもの

ネットワーク　標準

問題文

無線 LAN で使用される規格 IEEE 802.1X が規定しているものはどれか。

ア アクセスポイントが EAP を使用して,クライアントを認証する枠組み

イ アクセスポイントが認証局と連携し,パスワードをセッションごとに生成する仕組み

ウ 無線 LAN に接続する機器のセキュリティ対策に関する WPS の仕様

エ 無線 LAN の信号レベルで衝突を検知する CSMA/CD 方式の仕様

問17　解答・解説

ネットワーク　標準

正解：ア
アクセスポイントが**EAPを使用して**、クライアントを認証する枠組み

IEEE 802.1Xの3者構成

役割	機器
Supplicant（認証依頼者）	クライアントPC・デバイス
Authenticator（認証装置）	APやスイッチ
Authentication Server	**RADIUS**サーバ

- **EAP（Extensible Authentication Protocol）** で認証
- 企業無線LAN（WPA2/WPA3 Enterprise）で広く採用

情報分野の情勢
ゼロトラストで「接続＝信頼」の前提が崩れ、802.1Xの重要性が再評価。WPA3-Enterpriseは802.1Xを強制。IoT機器の急増で802.1X非対応デバイスの管理（NACとの組み合わせ）が課題。SD-WANやSSEとの統合も進行中。

問18　Ajaxの説明

Web技術　易

問題文

JavaScript などのスクリプト言語を使って,Web ブラウザに組み込まれているサーバとの非同期通信機能を利用する技術であり,地図の高速なスクロールや,キーボード入力に合わせた検索候補の逐次表示を実現するものはどれか。

ア Ajax　　イ CSS　　ウ DOM　　エ SAX

問18　解答・解説

Web技術　易

正解：ア　AJAX
JavaScriptを使ったブラウザ内蔵の**非同期通信機能**を利用する技術。ページ全体を再読み込みせずにサーバとデータ交換

選択肢の整理

選択肢	正体
Ajax ← ア	非同期通信技術（XMLHttpRequest / Fetch API）
CSS	スタイルシート言語
DOM	ドキュメントオブジェクトモデル（構造操作API）
SAX	XMLパーサAPIの方式

情報分野の情勢
現在はFetch API・WebSocket・SSEが後継として整備。React/Vue.js/AngularなどSPAフレームワーク内に吸収・自動化。セキュリティ観点ではCORS（Cross-Origin Resource Sharing）の誤設定が情報漏洩リスクとして継続。

問19　OSPFだけに当てはまる特徴

ネットワーク　標準

問題文

二つのルーティングプロトコル RIP-2 と OSPF とを比較したとき,OSPF だけに当てはまる特徴はどれか。
ア 可変長サブネットマスクに対応している。
イ リンク状態のデータベースを使用している。
ウ ルーティング情報の更新にマルチキャストを使用している。
エ ルーティング情報の更新を 30 秒ごとに行う。

問19　解答・解説

ネットワーク　標準

正解：イ
リンク状態のデータベース（LSDB）を使用する ← RIP-2にはない

RIP-2 vs OSPF 比較

比較項目	RIP-2	OSPF
アルゴリズム	ディスタンスベクタ	**リンクステート**
メトリック	ホップ数（最大15）	コスト（帯域幅ベース）
VLSM対応	○	○（共通なのでア×）
更新方式	定期（30秒）	変化時のみ（LSA）
マルチキャスト	224.0.0.9	224.0.0.5/6（共通なのでウ×）
リンク状態DB	**なし**	**あり（LSDB）← イ○**

情報分野の情勢
SD-WAN台頭後もOSPF/BGPはエンタープライズ・DCのコアプロトコルとして健在。AWS Direct Connect・Azure ExpressRoute等ではBGPが重要。OSPFの認証機能（MD5/SHA）設定がルートインジェクション攻撃対策として重要。

問20　HTTPステータスコードの説明

ネットワーク　易

問題文

HTTP のステータスコードに関する説明のうち、適切なものはどれか。
ア 100 番台は、リクエストを受けたサーバ側でエラーが発生したことを意味する。
イ 200 番台は、リクエスト内容に不備があるので、エラーが発生したことを意味する。
ウ 300 番台は、完了するためにリダイレクトなど更なる動作が必要なことを意味する。
エ 400 番台は、リクエストがサーバに正常に受信され、処理が完了したことを意味する。

問20　解答・解説

ネットワーク　易

正解：ウ
300番台は、完了するために**リダイレクトなど更なる動作が必要**なことを意味する

HTTPステータスコードの分類

コード	意味	代表例
1xx	情報（処理継続中）	100 Continue
2xx	成功	200 OK, 201 Created
3xx ← ウ	**リダイレクト（追加動作必要）**	301, 302 Found
4xx	クライアントエラー	400, 401, 403, 404
5xx	サーバエラー	500, 503

情報分野の情勢
HTTP/3（QUIC over UDP）がCloudflare・Google等で普及中。RESTful API設計でステータスコードの正確な利用（401 vs 403の使い分け）が必要。エラーレスポンスによる情報漏洩抑制もOWASP API Security Top 10の重要項目。

システム・DB／法律・計算・監査

問21〜問25

トランザクション ／ 結合テスト ／ 著作権 ／ 可用性計算 ／ システム監査

問21　DBMSがトランザクションのコミット処理を完了するタイミング

システム・DB　やや難

問題文

DBMS がトランザクションのコミット処理を完了するタイミングはどれか。

ア アプリケーションプログラムによるデータ更新命令完了時点

イ チェックポイント処理完了時点

ウ ログバッファへのコミット情報書込み完了時点

エ ログファイルへのコミット情報書込み完了時点

問21　解答・解説

システム・DB　やや難

正解：エ

ログファイルへのコミット情報書込み完了時点（ログバッファへの書込みでは不十分）

WAL（Write-Ahead Logging）の処理順序

① アプリが更新命令発行
② バッファプール（メモリ）に反映
③ ログバッファにコミット情報を書き込む
④ ログファイル（永続ストレージ）に書き出す ← ★コミット完了
⑤ バッファプールの内容をデータファイルに書き出す（チェックポイント）

情報分野の情勢

PostgreSQL/MySQL/SQLiteで広く採用。クラウドマネージドDB（RDS/Azure SQL）でも同原則が適用され、自動フェイルオーバー・PITRの基盤となる。NewSQL（CockroachDB/TiDB/Spanner）ではWAL＋Raft/Paxosで分散耐障害性を実現。

問22　ソフトウェア結合テスト方式

システム・DB　やや難

状況：アプリ層・ミドルウェア層の単体テスト完了、デバイスドライバ層が**未完了**

問題文

図のような階層構造で設計された組込みシステムがある（アプリケーション層／ミドルウェア層／デバイスドライバ層）。デバイスドライバ層の単体テスト工程が未終了で、アプリケーション層及びミドルウェア層の単体テストが先に終了した。この段階で行えるソフトウェア結合テストの方式として、適切なものはどれか。

ア サンドイッチテスト　　イ トップダウンテスト　　ウ ビッグバンテスト　　エ ボトムアップテスト

問22　解答・解説

システム・DB　やや難

正解：イ　トップダウンテスト
上位層から順に結合。未完成の下位層の代わりに**スタブ（stub）**を使用

結合テスト方式の比較

方式	進行方向	代替物	本問への適否
トップダウン ← イ	上→下	スタブ	○（ドライバ層をスタブ代替）
ボトムアップ	下→上	ドライバ	×（下位が未完成のため不可）
サンドイッチ	中間から両方	両方	×（複雑）
ビッグバン	一度に全部	—	×（規模が大きい場合不適）

情報分野の情勢
CI/CDパイプラインでテスト自動化が標準化。DevSecOpsではSAST/DAST/SCAをテストパイプラインに組み込むことが必須。AIを活用した自動テスト生成（GitHub Copilot等）も登場。

問23　著作権の帰属先

法律・著作権　標準

状況：開発請負契約書に著作権帰属の取り決めが**ない**場合

問題文

商用目的で開発するソフトウェアの開発請負契約書には、企業間で様々な事項を取り決めておく必要がある。この開発請負契約書に取決めがない場合に、ソフトウェアの著作権の帰属先に関する説明として、適切なものはどれか。ここで、ソフトウェアは注文者から委託された請負人が開発するものとする。

ア 請負人,注文者のどちらにも帰属しない。　イ 請負人と注文者の両方に帰属する。

ウ 請負人に帰属する。　エ 注文者に帰属する。

問23　解答・解説

法律・著作権　標準

正解：ウ　請負人に帰属する
著作権法第17条：著作権は**著作物を創作した者（著作者）**に原始帰属する

ポイント

- 契約に定めがない → 実際に開発した**請負人に帰属**
- 注文者に帰属させたいなら **「著作権の譲渡条項」** を契約書に明記
- 従業員が業務で作成した場合 → 法人著作（職務著作）として**使用者（会社）**に帰属する可能性

情報分野の情勢
GitHub Copilot等のAIが生成したコードの著作権帰属が新たな法的論点に。各国でAI生成物への著作権立法論議が継続中。SBOMの普及でOSSライセンス管理（GPL/MIT等）の重要性も増大。

問24　サービス可用性の計算

計算問題

問題文

サービス提供時間帯が毎日 0 時から 24 時までの IT サービスにおいて、ある年の 4 月1日0時から6月30日24時までのサービス停止状況は表のとおりであった。システムバージョンアップ作業に伴う停止時間は、サービス提供時間に含めないことが顧客との間で合意されている。4月1日から6月30日までの IT サービスのサービス可用性は何%か（小数第3位を四捨五入）。

停止理由①：システムバージョンアップ作業 → 5月2日22時～5月6日10時（84時間）

停止理由②：ハードウェア故障 → 6月26日10時～20時（10時間）

ア 95.52　　イ 95.70　　ウ 99.52　　エ 99.63

条件：4月1日～6月30日 ／ バージョンアップ停止（84時間）はサービス提供時間に含めない

問24　解答・解説

計算問題

正解：ウ　99.52%

計算過程

項目	計算	結果
期間の総時間	(30＋31＋30) 日 × 24時間	**2,184時間**
バージョンアップ停止（除外）	—	−84時間
サービス提供時間（分母）	2,184 − 84	**2,100時間**
ハードウェア故障停止	—	−10時間
サービス稼働時間（分子）	2,100 − 10	**2,090時間**
可用性	2,090 ÷ 2,100 × 100	**99.52%**

情報分野の情勢

クラウドSLAでは99.9〜99.99%（スリー〜フォーナイン）が標準。ファイブナイン（99.999%、年間約5分のダウンタイム）が求められるシステムも増加。マルチリージョン・アクティブ-アクティブ構成（HA）がクラウドアーキテクチャの標準に。

問25　システム監査基準（令和5年）のリスク評価に基づく監査計画

監査　標準

問題文

システム監査基準（令和5年）に基づくシステム監査において、リスク評価に基づいた監査計画の策定で考慮すべき事項として、適切なものはどれか。

ア 監査対象の不備を見逃して監査の結論を誤る監査リスクを完全に回避する監査計画を策定する。

イ システム監査におけるリスク・アプローチでは、各監査対象に対して均等に監査資源を配分する。

ウ システム監査に係るリスクのうち、監査対象に対するリスクは、統制リスクと残存リスクの二つに大別される。

エ 組織体内外の環境変化によってリスクが相当程度変化した場合には、監査計画の見直しを検討し,必要に応じて変更する。

問25　解答・解説

監査　標準

正解：エ
組織体内外の**環境変化によってリスクが相当程度変化した**場合には、監査計画の見直しを検討し、必要に応じて変更する

選択肢の誤りポイント

選択肢	誤りの理由
ア	監査リスクを「完全に回避」は不可能。許容水準を設定する
イ	リスク・アプローチは均等配分ではなく**重点配分**
ウ	監査リスクの三要素は「固有・統制・発見」

情報分野の情勢
令和5年基準改訂ではAI・クラウド・サプライチェーンリスクへの対応が強化。ISO/IEC 27001・SOC2・ISAE3402との整合性も求められる。クラウド設定監査・ペネトレーションテスト結果活用・インシデント対応能力評価が現代的な監査テーマに。

出題傾向まとめと学習指針

重点学習分野

優先度	分野
★★★	攻撃手法（最新含む）
★★★	セキュリティ管理ツール・組織
★★★	暗号技術（PQC含む）
★★☆	認証・PKI
★★☆	Webセキュリティ
★★☆	ネットワーク基礎
★☆☆	計算・法律・監査

優先学習の根拠

- 攻撃手法：毎回4問前後、最新手法まで出題
- 管理ツール：UEBA・CSPM等クラウド系が近年急増
- 暗号：PQCは今後も継続出題が確実視
- 認証：毎回コンスタントに3問前後
- 基礎技術：36%を占め無視できない

> 計算・法律・監査は各1問。基礎を確認し確実に取る。

近年の新傾向キーワード

今後も出題が予想される新興トピック：

AI/MLセキュリティ

- モデルインバージョン
- ポイズニング攻撃
- モデル抽出攻撃
- 敵対的サンプル
- MITRE ATLAS

耐量子暗号（PQC）

- ML-KEM (FIPS 203)
- ML-DSA (FIPS 204)
- 格子暗号
- CNSA 2.0

クラウドセキュリティ

- CSPM
- CWPP
- CASB
- CNAPP
- CIEM

ゼロトラスト

- SDP
- IAP
- マイクロセグメンテーション
- SSE

サプライチェーンセキュリティ

- SBOM
- ソフトウェアサプライチェーン
- Coordinated Vulnerability Disclosure

脅威インテリジェンス

- MITRE ATT&CK
- STIX/TAXII
- XDR
- 脅威ハンティング

参照規格・ドキュメント　＋　正解一覧

主要参照規格

規格/文書	関連問
CRYPTREC暗号リスト	問1
NIST PQC（FIPS 203/204/205）	問3
NIST SP 800-63-3	問11
MITRE ATT&CK	問12
IEEE 802.1X	問17
システム監査基準（令和5年）	問25

正解一覧

問	正	問	正	問	正
1	ウ	10	イ	19	イ
2	イ	11	ア	20	ウ
3	エ	12	ア	21	エ
4	エ	13	イ	22	イ
5	ア	14	エ	23	ウ
6	イ	15	イ	24	ウ
7	ア	16	エ	25	エ
8	ア	17	ア		
9	エ	18	ア		

合格を目指して

試験の傾向を押さえ、着実に得点を積み重ねよう

令和7年度 秋期 情報処理安全確保支援士試験 午前 II 分析資料